

El Paradigma Pre-Flight en la Seguridad de IA Generativa

Por qué la gobernanza nativa en el endpoint es la única respuesta determinista al riesgo de inferencia

«La seguridad corporativa deja de preguntar qué ocurrió con el prompt y empieza a decidir si ese prompt debe llegar a existir como solicitud para el proveedor.»

1. EL ÁNGULO CIEGO DE LA CIBERSEGURIDAD TRADICIONAL

Con la adopción masiva de Large Language Models (LLMs) y asistentes de productividad, las empresas se enfrentan a un desafío regulatorio y operativo sin precedentes: la fuga inadvertida de propiedad intelectual, secretos bancarios y datos personales identificables (PII).

Las aproximaciones tradicionales (Proxies Cloud MITM, CASBs convencionales y pasarelas perimetrales) intentan inspeccionar el tráfico cuando ya ha abandonado el puesto de trabajo. Este modelo adolece de tres fallas críticas:

- Ruptura de protocolos modernos:** Los flujos continuos (WebSockets, SSE y HTTP/2 streaming) sufren latencias inaceptables (+250 ms a +800 ms).
- Fuga consumada en origen:** Si el proxy sufre un bypass o indisponibilidad, el dato sensible ya fue entregado a los servidores de inferencia.
- Coste computacional residual:** El modelo de IA procesa tokens de peticiones maliciosas o no autorizadas antes de que se emita una alerta tardía.

2. LA DISRUPCIÓN: AI INTERACTION RUNTIME ENFORCEMENT

S.A.A.R.E. traslada el plano de control y decisión al **punto cero de la interacción del usuario**. Mediante la distribución de paquetes de políticas compiladas y firmadas por el Control Plane (*Policy Bundles*), el agente local ejecuta la evaluación en memoria en **P50 1.4 ms**.

Criterio de Evaluación	Soluciones Perimetrales (CASB / Proxy)	S.A.A.R.E. MS3V Interaction Runtime
Punto de Control	Externo al endpoint (Pasarela intermedia).	Nativo en el ciclo de interacción de la IA.

Criterio de Evaluación	Soluciones Perimetrales (CASB / Proxy)	S.A.A.R.E. MS3V Interaction Runtime
Consumo de Inferencia	Inferencia parcial o completa procesada.	Zero-Submission: 0 tokens entregados al proveedor.
Impacto de Latencia	+200 ms a +800 ms (Ruptura de conexiones).	P50 1.4 ms (Decisión en memoria volátil).
Validez Pericial	Logs centrales modificables por administradores.	Decision Records sellados en Hash-Chain W3C.
Resiliencia de Red	Dependencia total de conexión hacia el proxy.	Capacidad Offline-First mediante Policy Bundles.

3. CUMPLIMIENTO REGULATORIO CERTIFICADO

Cada decisión emitida por el motor S.A.A.R.E. no genera un simple log de texto, sino un **Decision Record pericial inmutable** con encadenamiento de hashes tipo Merkle y firma criptográfica asimétrica, dando respuesta vinculante a los requerimientos de:

- **EU AI Act (Art. 15):** Garantía de robustez, trazabilidad técnica y mitigación proactiva de inyecciones de código (Jailbreaks).
- **DORA (Digital Operational Resilience Act):** Resiliencia operativa en el sector financiero con capacidad offline y cero fugas de datos confidenciales.
- **RGPD & LOPDGDD (Art. 5):** Principio de minimización y anonimización de datos personales en tiempo real antes de la salida de red.